INTRODUCCIÓN A LA CIBERSEGURIDAD · 2026

Solucionario razonado

Práctica 1 (partes 1 y 2) · Práctica 2 (partes 1, 2 y 3)

---

92 ejercicios de repaso práctico, organizados por el contenido de las cinco partes de las guías. Todos están conectados con un ejercicio o conjunto de ejercicios de las prácticas originales; los PDFs teóricos se utilizan como apoyo y explicación, no como temario independiente.

Cada respuesta corresponde al mismo número del cuadernillo. En problemas autocontenidos se brinda un resultado comprobable; para retos que dependen de archivos o servicios CTF ausentes se explica el método, sin inventar flags ni observaciones.

CONTENIDOS

PRÁCTICA 1 · CRIPTOGRAFÍA · PARTE 1
Codificación, cifrados clásicos, hashes, AES y XOR. Preguntas 1 a 25 (25).

PRÁCTICA 1 · CRIPTOGRAFÍA · PARTE 2
RSA, Diffie-Hellman, esteganografía y PGP. Preguntas 26 a 40 (15).

PRÁCTICA 2 · CSIRT · PARTE 1
Direcciones IP, RIR/NIR, WHOIS/RDAP y dominios. Preguntas 41 a 51 (11).

PRÁCTICA 2 · CSIRT · PARTE 2
Correo SMTP, logs SSH, canales encubiertos y análisis de archivos. Preguntas 52 a 69 (18).

PRÁCTICA 2 · MALWARE · PARTE 3
Análisis estático/dinámico, IOC, persistencia y documentos maliciosos. Preguntas 70 a 92 (23).

FUENTES UTILIZADAS

• Práctica 1 - Criptografía - Parte 1.pdf; Práctica 1 - Parte 2.pdf.

• Práctica 2 - Parte 1.pdf; Práctica 2 - Parte 2.pdf; Práctica 2 - parte 3.pdf.

• Teorías y explicaciones de apoyo: 03 Conceptos Básicos.pdf; 04 Cripto parte 1.pdf; 05 CSIRT - Recursos de Internet.pdf; 06 encabezados_smtp.pdf; 07 CSIRT - Gestión de incidentes.pdf; 08 Analisis_de_malware.pdf.

• Complemento metodológico: 02 Writeup example.pdf. Los nombres y direcciones *.example o de rangos de documentación se usan sólo en ejemplos inventados.

• El PDF 09 Reversing.pdf y 10 reversing_2.pdf no se usan como fuente principal, porque la práctica 3 de reversing no fue incluida entre las prácticas solicitadas.

PRÁCTICA 1 · CRIPTOGRAFÍA · PARTE 1

01 · Codificar no es cifrar

Referencia: Ej. 1; teoría 04, codificación

Un participante encuentra un texto en Base64 y afirma que está protegido criptográficamente. ¿Qué error conceptual comete? ¿Cuándo hace falta una clave?

Solución: Base64 es una codificación reversible con reglas públicas: no busca confidencialidad ni necesita una clave secreta. Cifrar busca que el texto claro no pueda recuperarse sin el material criptográfico adecuado. En la práctica se mencionan también ASCII, Unicode y representación hexadecimal como codificaciones.

02 · ASCII decimal

Referencia: Ej. 1(a); teoría 04, ASCII

Convertí la secuencia decimal ASCII 73 67 123 65 125 a texto. Indicá por qué el valor 123 no es una letra.

```
73 67 123 65 125
```

Solución: 73 → I, 67 → C, 123 → {, 65 → A y 125 → }. Por lo tanto, el texto es IC{A}. ASCII asigna códigos a signos de puntuación además de letras y dígitos.

03 · Decodificación Base64

Referencia: Ej. 1(b); teoría 04, Base64

Decodificá la cadena y explicá qué indica el signo = cuando aparece al final de una cadena Base64.

```
SUN7YmFzZTY0X25vX2VzX2NpZnJhZG99
```

Solución: La secuencia decodifica como IC{base64_no_es_cifrado}. En Base64, = se utiliza como relleno (padding) para completar grupos de salida: no se trata de una contraseña ni forma parte del mensaje original.

04 · Hexadecimal a texto

Referencia: Ej. 1(e); teoría 04, ASCII hexadecimal

Transformá los bytes hexadecimales en texto ASCII y explicá cómo distinguir 49 hexadecimal de 49 decimal.

```
49 43 7b 68 65 78 7d
```

Solución: 49 hex = 73 decimal = I; 43 hex = 67 decimal = C; 7b = {; 68 = h; 65 = e; 78 = x; 7d = }. El resultado es IC{hex}. El valor 49 decimal correspondería al carácter «1», no a «I».

05 · Alfabeto numérico

Referencia: Ej. 1(c-d); codificación alfabética

Con A=1, B=2, ..., Z=26, interpretá 9-3-19-5-7-21-18-15. ¿Qué supuesto debés verificar antes de aplicar esta regla a una secuencia ajena?

```
9-3-19-5-7-21-18-15
```

Solución: El resultado es ICSEGURO (9=I, 3=C, 19=S, 5=E, 7=G, 21=U, 18=R, 15=O). Antes de resolver otra cadena hay que verificar el alfabeto, el origen del índice (A=0 o A=1), separadores y tratamiento de espacios.

06 · Braille como sistema de representación

Referencia: Ej. 1(f); codificaciones no habituales

Al hallar un texto con celdas Braille Unicode, ¿qué pasos seguirías para interpretarlo y por qué no corresponde asumir que es un cifrado?

Solución: Hay que reconocer el alfabeto Braille, mapear cada patrón de puntos a su letra o signo, conservar separadores y reconstruir la frase. Es un sistema de representación; que el lector desconozca el alfabeto no convierte la codificación en criptografía.

07 · Texto visible y datos ocultos

Referencia: Ej. 1(g); Práctica 1, Parte 2, ej. 17

Una imagen exhibe la frase «no hay nada acá», pero el reto advierte que hay otro mensaje. Nombrá cuatro lugares o técnicas que revisarías antes de concluir que la imagen está vacía.

Solución: Revisaría metadatos y comentarios, cadenas incrustadas en el archivo, bytes añadidos al final, LSB de píxeles y posibles datos embebidos con esteganografía. También inspeccionaría si hay un archivo oculto extraíble con steghide. No se puede asegurar cuál técnica fue usada sin disponer de la imagen.

08 · Servicio interactivo de codificación

Referencia: Ej. 2; estrategia de desafíos de codificación

En un servicio CTF cada conexión muestra una cadena distinta codificada y espera una respuesta en segundos. Describí una estrategia de resolución reproducible, sin suponer cuál es la flag.

Solución: Registrar entradas y salidas, reconocer el formato, probar el decodificador sobre ejemplos, automatizar la lectura y el envío sólo dentro del entorno del reto, gestionar saltos de línea y validar el resultado recibido. Si el formato cambia entre conexiones, el script debe identificarlo antes de decodificar.

09 · Transposición por inversión

Referencia: Ej. 3(a); teoría 04, criptografía clásica

Reconstruí el texto de esta cadena invertida e indicá si cambió la identidad de las letras o su posición.

```
}odnum_aloh{CI
```

Solución: Al invertir el orden se obtiene IC{hola_mundo}. Es una transposición: los caracteres no se sustituyen por otros, sólo se reordenan.

10 · Sustitución César

Referencia: Ej. 3(b); teoría 04, César

Descifrá el mensaje suponiendo que fue cifrado con un desplazamiento César de +3 sobre letras y que los signos se conservaron. Clasificá el método.

```
LF{fulswr}
```

Solución: Se resta 3 a cada letra (L→I, F→C, f→c, etc.). Se obtiene IC{cripto}. Es sustitución monoalfabética, no transposición.

11 · Transposición rail fence

Referencia: Ej. 3(d); rail fence

El texto CBRIE fue cifrado con rail fence de 2 rieles y sin espacios. Recuperá el original y describí el reparto de letras.

```
CBRIE
```

Solución: Con 5 posiciones, el primer riel contiene las posiciones 1, 3 y 5: C, B, R. El segundo contiene posiciones 2 y 4: I, E. Al intercalar se obtiene CIBER. Es transposición porque el alfabeto permanece igual.

12 · Cifrado columnar

Referencia: Ej. 3(e); transposición columnar

Se cifró THE SKY IS BLUE (sin espacios) con la clave CAT, ordenando columnas alfabéticamente A, C, T. Explicá cómo se reconstruye el mensaje a partir de HKSUTSILEYBE.

```
Texto cifrado: HKSUTSILEYBE
Clave: CAT
```

Solución: En una tabla de tres columnas C-A-T y cuatro filas, se leen los bloques de cuatro caracteres HKSU (columna A), TSIL (columna C) y EYBE (columna T). Reubicando en el orden C-A-T y leyendo por filas se recupera THESKYISBLUE. Es transposición.

13 · Vigenère y contraseña

Referencia: Ej. 3(c); cifrado de sustitución

Un mensaje cifrado con Vigenère y clave KEY produce RIJVS. Descifralo y explicá por qué el conocimiento de la clave importa.

```
Cifrado: RIJVS
Clave: KEY
```

Solución: Al restar las posiciones de KEYKE a RIJVS módulo 26 se obtiene HELLO. La clave define el desplazamiento de cada posición. A diferencia de César, Vigenère emplea desplazamientos que varían según la clave repetida.

14 · Sustitución frente a transposición

Referencia: Ej. 3; clasificación de métodos

Dos cifrados transforman CASA en FDVD y en ASAC. ¿Cuál parece sustitución y cuál transposición? Indicá una limitación de sacar conclusiones sólo con un ejemplo.

Solución: FDVD corresponde a César +3 (sustitución: C→F, A→D, S→V). ASAC conserva las mismas letras y cambia el orden (transposición). Un único par de muestras no permite identificar inequívocamente un algoritmo: muchas transformaciones podrían generar una misma salida.

15 · Automatizar variantes de un cifrado

Referencia: Ej. 4; retos remotos de criptografía clásica

Un desafío remoto responde si una frase se descifró correctamente, pero no revela qué desplazamiento César usa. ¿Cómo encontrarías la respuesta de manera sistemática?

Solución: Probar los 26 desplazamientos posibles del alfabeto latino, conservar el texto con sentido y verificarlo en el servicio del CTF. Un script puede generar las 26 variantes localmente. Si hay mayúsculas, acentos u otros símbolos, deben declararse las reglas del alfabeto.

16 · Longitud de hashes

Referencia: Ej. 5; teoría 04, funciones hash

Un digest en hexadecimal tiene 32 caracteres, otro 40, otro 64 y otro 128. ¿Qué tamaños binarios representan? ¿Qué se puede inferir y qué NO se puede confirmar?

Solución: Representan 128, 160, 256 y 512 bits respectivamente (4 bits por dígito hexadecimal). Son longitudes compatibles, por ejemplo, con MD5, SHA-1, SHA-256 y SHA-512; la longitud por sí sola no identifica el algoritmo de manera concluyente.

17 · Colisiones y preimagen

Referencia: Ej. 5; teoría 04, funciones hash

Explicá por qué dos archivos pueden tener el mismo hash y por qué un sitio que «recupera una contraseña desde MD5» no necesariamente invierte matemáticamente MD5.

Solución: Un hash de tamaño fijo agrupa un espacio de entradas más grande y puede tener colisiones. Los sitios de consulta suelen buscar valores ya calculados en diccionarios o tablas; hallan una entrada candidata que produce el digest, no invierten una función criptográfica general. También podría existir otra preimagen.

18 · Comprobar un candidato

Referencia: Ej. 5-7; teoría 04, seguridad de hashes

Te dicen que el SHA-256 de un archivo coincide con uno publicado. ¿Qué comprobación harías? ¿Por qué la coincidencia no autentica por sí sola al publicador?

Solución: Calcularía SHA-256 del archivo local y lo compararía bit a bit con el esperado. Eso prueba coincidencia respecto del resumen recibido, sujeto a las propiedades del hash; si el digest se obtuvo de una fuente alterable o no confiable, un adversario podría modificar tanto el archivo como el resumen.

19 · Ataque de diccionario controlado

Referencia: Ej. 7; diccionario rockyou

Un CTF te da el SHA-256 de una contraseña y avisa que está entre las primeras 100 entradas de rockyou.txt. ¿Cómo la buscarías sin probar todas las combinaciones posibles?

Solución: Se calculan los hashes SHA-256 de esas 100 palabras y se comparan con el digest entregado. Se puede usar hashcat, John the Ripper o un pequeño script. Esto es una búsqueda offline en un diccionario acotado, no una inversión del hash; sólo debe realizarse sobre material autorizado.

20 · Hash con salt conocido

Referencia: Ej. 8; teoría 04, contraseñas y salt

El reto define MD5(salt || password), salt=IntroCiberseguridad y el digest siguiente. Entre las candidatas «mate», «sol» y «luna», ¿cuál corresponde? ¿Por qué importa el orden?

```
Digest: 6bff121a17aae857825427eab59ebe13
```

Solución: La candidata es mate. MD5("IntroCiberseguridadmate") = 6bff121a17aae857825427eab59ebe13. En el caso planteado el salt se concatena primero: cambiarlo por MD5(password || salt) da otro resultado. El salt no reemplaza a un algoritmo de derivación de contraseñas resistente a ataques offline.

21 · Orden de operaciones

Referencia: Ej. 9; teoría 04, AES-ECB

La práctica presenta un resultado de AES-128-ECB que luego fue codificado en Base64. Ordená las transformaciones correctas para recuperar el texto original y señalá los datos que deben conocerse.

Solución: Primero se decodifica Base64 para recuperar los bytes cifrados; luego se descifra con AES-128 en modo ECB usando exactamente la clave de 16 bytes, y finalmente se retira el padding si corresponde y se interpreta el plaintext con su codificación. Base64 no agrega seguridad al cifrado.

22 · Riesgo de ECB

Referencia: Ej. 9; teoría 04, modos de bloque

Se cifran dos bloques de 16 bytes idénticos con la misma clave AES-ECB. ¿Qué relación habrá entre los bloques cifrados? Comparalo con el encadenamiento CBC.

Solución: En ECB, dos bloques de texto plano iguales, bajo la misma clave, producen bloques cifrados iguales; se filtran patrones. En CBC, cada bloque plano se combina con el bloque cifrado anterior (y el primero con un IV), de modo que la repetición de bloques no tiene ese mismo efecto directo. Esto no convierte automáticamente a CBC en un modo autenticado.

23 · XOR reversible

Referencia: Ej. 10; XOR de un byte

El texto IC{XOR} se cifró haciendo XOR de cada byte con la clave 0x2a. Dado el hexadecimal de salida, recuperá el texto y expresá la propiedad algebraica utilizada.

```
63 69 51 72 65 78 57
```

Solución: El texto es IC{XOR}. Basta aplicar XOR con 0x2a a cada byte del ciphertext, porque (x XOR k) XOR k = x. Por ejemplo, 0x63 XOR 0x2a = 0x49, que representa I.

24 · Espacio de claves de XOR

Referencia: Ej. 10; fuerza bruta

Un reto utiliza XOR con clave de un byte desconocida. ¿Cuántas claves existen? Describí cómo decidir si una candidata produce texto inteligible.

Solución: Existen 2^8 = 256 valores posibles, de 0 a 255. Se prueba cada clave en todos los bytes y se evalúa el resultado por su proporción de caracteres imprimibles, estructura del mensaje y formato esperado; no se debe elegir una candidata sólo porque genera letras aisladas.

25 · Clave efímera y semilla

Referencia: Ej. 11; XOR con clave temporal

Un servicio CTF genera una clave XOR «temporal» al conectarse. ¿Qué observaciones permitirían saber si la clave se reutiliza o deriva de una marca temporal? ¿Qué no se puede concluir sin registros del reto?

Solución: Compararía conexiones sucesivas, instante de generación, cifrados del mismo texto, mensajes conocidos y comportamiento frente a reconexiones. Una fuente de tiempo predecible puede disminuir la entropía efectiva; sin capturas o implementación no es posible afirmar el algoritmo, la semilla exacta ni una flag.

PRÁCTICA 1 · CRIPTOGRAFÍA · PARTE 2

26 · RSA, cálculo completo

Referencia: Ej. 12; RSA con p y q

Con RSA de juguete p=61, q=53, e=17 y C=2790: calculá n, φ(n), d y el mensaje entero M. Mostrá la relación usada para descifrar.

```
p=61 q=53 e=17 C=2790
```

Solución: n=61·53=3233; φ(n)=(61−1)(53−1)=3120; d es el inverso de 17 módulo 3120, igual a 2753; M=C^d mod n=65. Como prueba, 65^17 mod 3233 = 2790. Estos valores son sólo didácticos y no tienen seguridad real.

27 · RSA: número frente a bytes

Referencia: Ej. 12; representación de plaintext

Al descifrar RSA obtenés el entero decimal 65. ¿Qué dato extra necesitás para afirmar que el mensaje era la letra A? ¿Qué cambia con mensajes de varios bytes?

Solución: Necesitás conocer la representación acordada del mensaje. Si se usó ASCII sin padding adicional, 65 representa A; con otros esquemas o codificaciones podría interpretarse distinto. Para mensajes mayores hay que reconstruir bytes con el orden y longitud correctos, y tener en cuenta el padding real del criptosistema.

28 · Factorización de n

Referencia: Ej. 14-15; RSA sin factores

Se publica (n=3233, e=17) pero no los factores de n. ¿Cómo recuperarías la clave privada en este ejemplo pequeño? ¿Por qué el mismo procedimiento no escala a claves RSA correctamente generadas?

Solución: Factorizando 3233 se obtiene 61·53; desde ahí se calcula φ(n)=3120 y el inverso modular d=2753. La seguridad práctica de RSA de tamaño adecuado se apoya en que factorizar números grandes elegidos correctamente es computacionalmente difícil con técnicas clásicas conocidas.

29 · No confundir parámetros RSA

Referencia: Ej. 13-15; validez del descifrado

Una persona ve e=65537 en un enunciado RSA y asegura que ésa es la clave privada. Explicá el error y qué información necesita el procedimiento habitual de descifrado.

Solución: e es el exponente público comúnmente elegido, no el secreto. Para descifrar hace falta d y n; d se obtiene a partir de φ(n) o λ(n) cuando se conocen los factores secretos de n. Conocer únicamente e y un ciphertext no basta para recuperar de forma general el mensaje.

30 · Diffie-Hellman numérico

Referencia: Ej. 16; intercambio Diffie-Hellman

En un ejemplo didáctico de Diffie-Hellman p=23, g=5, Alice tiene a=6 y Bob b=15. Calculá A, B y la clave compartida que cada uno obtiene.

```
p=23 g=5 a=6 b=15
```

Solución: Alice publica A=5^6 mod 23=8; Bob publica B=5^15 mod 23=19. Alice calcula 19^6 mod 23=2 y Bob 8^15 mod 23=2. El secreto compartido coincide, sin haberse enviado directamente por la red.

31 · ¿Qué no autentica Diffie-Hellman?

Referencia: Ej. 16; protocolo DH

¿Por qué un intercambio Diffie-Hellman sin autenticación no evita por sí solo un ataque de intermediario (MitM)?

Solución: Un atacante que intercepte y reemplace valores públicos puede negociar un secreto independiente con cada extremo, haciéndoles creer que hablan entre sí. Para autenticar participantes deben usarse certificados, firmas u otros mecanismos adecuados al protocolo.

32 · Esteganografía en imagen

Referencia: Ej. 17; extracción con steghide

Tenés una imagen de un reto y una contraseña de extracción. ¿Qué comandos de steghide usarías para inspeccionar y extraer datos, y qué resultado no podés adivinar sin el archivo?

```
steghide info imagen.jpg
steghide extract -sf imagen.jpg -p CLAVE
```

Solución: Puede usarse «steghide info imagen.jpg» para inspeccionar y «steghide extract -sf imagen.jpg -p CLAVE» para intentar extraer un archivo. Luego hay que verificar el nombre, formato y contenido extraídos. Sin la imagen real no se puede inventar el secreto ni confirmar que steghide fue el método.

33 · Recuperar LSB

Referencia: Ej. 17; esteganografía LSB

El bit menos significativo de ocho bytes de píxeles contiene una letra ASCII en orden de bit más significativo a menos significativo. ¿Qué letra es?

```
10010010 10100011 11010100 01000100
00110011 01000100 10100000 10010001
```

Solución: Los últimos bits son 0 1 0 0 1 0 0 1 = 01001001 binario = 0x49 = 73 decimal = I. El ejercicio ilustra LSB; en una imagen real deben conocerse canal, orden de píxeles, formato y longitud del mensaje.

34 · Esteganografía de audio

Referencia: Ej. 18; mensaje en audio

Al examinar un WAV aparentemente normal, ¿qué verificaciones harías para hallar un mensaje oculto antes de modificarlo?

Solución: Identificaría formato y metadatos, buscaría datos anexados y cadenas, escucharía el audio, observaría espectrograma y canales por separado e investigaría modificaciones de bits menos significativos. Trabajaría sobre una copia para preservar la evidencia. El método y mensaje precisos requieren el archivo original.

35 · Firmar no es cifrar

Referencia: Ej. 19; PGP y GnuPG

Diferenciá tres operaciones de OpenPGP: firmar, cifrar para otra persona y verificar una firma. ¿Cuáles dan confidencialidad y cuáles autenticidad?

Solución: Cifrar con la clave pública del destinatario busca confidencialidad; firmar con la clave privada del remitente permite verificar origen e integridad si la clave pública es confiable; verificar usa la clave pública y contrasta la firma. Una firma sola no vuelve secreto el contenido.

36 · Validación de firmas PGP

Referencia: Ej. 19, episodio 2; mensajes auténticos

Recibís dos textos con la misma afirmación. Uno tiene firma válida y otro no. ¿Qué se puede afirmar del primero y qué comprobación de confianza es indispensable?

Solución: Una firma válida significa que el contenido concuerda con la firma generada por la clave privada correspondiente a la clave pública usada. Debe validarse que esa clave pública pertenezca realmente al remitente, por ejemplo contrastando la huella digital mediante un canal confiable. Una firma válida de una clave desconocida no prueba identidad.

37 · Descifrado PGP con contraseña

Referencia: Ej. 20; PGP simétrico con diccionario

Un archivo cifrado con OpenPGP simétrico utiliza una passphrase tomada de un diccionario dado. ¿En qué se diferencia el procedimiento de descifrado respecto del uso de una clave privada RSA?

Solución: En PGP simétrico se usa una contraseña para derivar material criptográfico y descifrar; se prueban candidatos autorizados del diccionario y se observa si el descifrado es válido. En cifrado asimétrico se necesita la clave privada del destinatario. No se puede deducir la passphrase concreta sin el archivo y los candidatos.

38 · Cifrar con la clave pública en GPG

Referencia: Ej. 21; mensaje ASCII armor

Escribí un comando GPG para cifrar archivo.txt con la clave pública de destino@ejemplo.invalid y guardar una salida ASCII armor. ¿Qué debe estar preparado antes?

```
gpg --armor --encrypt --recipient destino@ejemplo.invalid \
--output archivo.txt.asc archivo.txt
```

Solución: Debe importarse y comprobarse la clave pública correcta (incluida su huella). Por ejemplo: «gpg --armor --encrypt --recipient destino@ejemplo.invalid --output archivo.txt.asc archivo.txt». El resultado es un mensaje ASCII armor; no hace falta ni corresponde utilizar la clave privada del destinatario para cifrar.

39 · Identidad y distribución de claves

Referencia: Ej. 19-21; error de confianza

Una persona descarga de un foro una clave que dice pertenecer a Bob y cifra un secreto para Bob. ¿Qué ataque sigue siendo posible incluso si el cifrado es sólido?

Solución: Si la clave fue sustituida por la de un atacante, el mensaje será cifrado para el atacante. Antes de confiar debe verificarse la huella de la clave por un medio autenticado, y no sólo por nombre o dirección de correo. La criptografía no arregla por sí sola una distribución de claves comprometida.

40 · Evidencia para recuperación de secretos

Referencia: Ej. 22; recuperar una contraseña propia

Un ejercicio plantea recuperar una contraseña olvidada a partir de datos cifrados, pero no entrega el archivo. ¿Qué evidencia pedirías y cómo distinguirías recuperación, descifrado y ataque de diccionario?

Solución: Primero identificaría formato, algoritmo, KDF, salt, parámetros, mecanismo de protección y datos disponibles; luego elegiría una técnica compatible con el material y autorización. Recuperar una contraseña por candidatos no equivale a «revertir» una función hash. Sin el archivo y su estructura no existe una solución o flag verificable.

PRÁCTICA 2 · CSIRT · PARTE 1

41 · Mapa de los RIR

Referencia: Ej. 1-2; teoría 05, RIR

Relacioná ARIN, APNIC, LACNIC, RIPE NCC y AFRINIC con sus regiones generales e identificá cuál corresponde de modo general a Argentina.

Solución: ARIN: América del Norte y algunas islas del Caribe/Atlántico; APNIC: Asia-Pacífico; LACNIC: América Latina y Caribe; RIPE NCC: Europa, Oriente Medio y parte de Asia Central; AFRINIC: África. Argentina pertenece a la región de LACNIC. Las bases pueden contener asignaciones históricas o delegaciones que requieren seguimiento.

42 · RIR y NIR

Referencia: Ej. 1-2; NIR

La práctica menciona NIR en Brasil y México. Explicá cómo se vinculan RIR y NIR y por qué una consulta puede requerir identificar ambos niveles.

Solución: El RIR administra recursos en su región y puede delegar funciones de asignación a un NIR nacional. La práctica identifica a Brasil y México como NIR de la región LACNIC. Para determinar responsable registral de un recurso concreto se consulta la base pertinente, no se infiere sólo por la geolocalización de la IP.

43 · Elegir contacto abuse

Referencia: Ej. 1; teoría 05, contactos

Una respuesta RDAP incluye tres correos: administrativo, técnico y abuse. ¿A cuál enviarías una denuncia de actividad maliciosa originada en esa red y por qué?

Solución: Se elige preferentemente el contacto abuse, porque es el canal previsto para incidentes o abuso de la red. El contacto administrativo gestiona cuestiones registrales y el técnico cuestiones técnicas generales. Conviene adjuntar IP, timestamps con zona horaria y evidencia observada.

44 · Analizar respuesta RDAP

Referencia: Ej. 1; protocolo RDAP

Interpretá esta ficha RDAP ficticia: identificá el bloque, la entidad y el contacto al que remitirías un incidente. ¿Es el registro prueba de que la entidad ejecutó personalmente el ataque?

```
network: 203.0.113.0/24
entity: Laboratorio Ejemplo
tech: noc@lab.example
abuse: abuse@lab.example
```

Solución: El bloque es 203.0.113.0/24, figura a nombre de Laboratorio Ejemplo y el contacto de abuso es abuse@lab.example. Sólo registra a quién corresponde el recurso: no prueba quién operaba una IP específica ni atribuye identidad del atacante.

45 · WHOIS frente a RDAP

Referencia: Ej. 1-2; teoría 05, WHOIS/RDAP

¿Por qué RDAP es conveniente para automatizar consultas de IP y por qué un resultado de WHOIS podría no coincidir literalmente con RDAP?

Solución: WHOIS ofrece respuestas de texto libre y heterogéneas; RDAP usa una representación estructurada, normalmente JSON, que simplifica el procesamiento. La práctica advierte que las bases pueden diferir en actualización o detalle y prefiere RDAP en IP. Hay que verificar las fechas y la fuente de ambos resultados.

46 · Bloque histórico incorrectamente atribuido

Referencia: Ej. 2; teoría 05, ERX/legacy

Consultás una IP y WHOIS muestra ERX-NETBLOCK de APNIC, aunque la red se administra en otra región. ¿Por qué puede ocurrir y qué harías?

Solución: Existen asignaciones legacy anteriores a la creación de los RIR actuales. Algunos servidores muestran datos genéricos históricos. Seguiría referencias al registro vigente, contrastaría RDAP y, si corresponde, consultaría el servidor WHOIS correcto de forma explícita, como ejemplifica la teoría con LACNIC.

47 · Consultar dirección IPv6

Referencia: Ej. 1-2; IPv6

La práctica incluye 2800:340:199:202::1. ¿Qué cambia al buscar su titular frente a una IPv4? ¿Qué NO se deduce del prefijo sin consultar un registro?

Solución: El objetivo es idéntico: consultar RDAP/WHOIS para conocer el bloque asignado y contacto abuse, usando una dirección IPv6 válida como clave de consulta. No se puede deducir con certeza el titular, NIR o correo de abuso a partir del prefijo aislado; debe consultarse la información registral.

48 · Registry, registrar y registrant

Referencia: Ej. 3-4; DNS de dominios

Describí la función de registry, registrar y registrant en el registro de un dominio. ¿Cuál de los tres administra el nombre por haberlo adquirido?

Solución: Registry mantiene el registro autoritativo del TLD; registrar comercializa y gestiona el registro del dominio ante el registry; registrant es la persona o entidad que registra el nombre. El registrant es el titular registral, aunque sus datos públicos pueden estar protegidos.

49 · Denunciar a titular vs a registrador

Referencia: Ej. 3-4; consulta de dominios

El CTF pide primero contactar al registrant por un nombre de dominio y después reportar abuso al registrar. ¿Por qué no siempre es la misma dirección?

Solución: El titular registral y el intermediario que vende/gestiona el dominio cumplen roles distintos. Para contactar al registrant se busca su correo o un formulario de privacidad; para abuso del registrar se busca el contacto específico del registrador, normalmente publicado en sus datos de registro.

50 · Privacidad registral

Referencia: Ej. 3-4; WHOIS de dominios

Una ficha WHOIS de dominio no muestra nombre, domicilio ni correo del registrant, pero sí un formulario de contacto de privacidad. ¿Cuál sería una conclusión correcta?

Solución: La ausencia de datos directos puede deberse a servicios de privacidad o protección de datos, no demuestra que el dominio sea falso. Debe usarse el punto de contacto que ofrece el registro y diferenciarlo del correo de abuso del registrar. El contenido preciso de los dominios originales requiere consultas actuales.

51 · Registro de dominios .ar

Referencia: Ej. 3-4; teoría 05, dominio .ar

Según la práctica, ¿qué particularidad tiene NIC.ar respecto de los roles de registry y registrar? ¿Puede extrapolarse automáticamente a todo gTLD?

Solución: Para .ar la práctica indica que NIC.ar ejerce ambas funciones. No es regla general: en otros TLD el registry y múltiples registrars son organizaciones diferentes. El detalle debe verificarse en los servicios registrales apropiados.

PRÁCTICA 2 · CSIRT · PARTE 2

52 · DNS MX y prioridad

Referencia: Ej. 5-6; teoría 06, SMTP

El DNS devuelve mx1.example (prioridad 10) y mx2.example (prioridad 20). ¿Qué significa cada registro y cuál tiene preferencia de entrega?

```
10 mx1.example
20 mx2.example
```

Solución: Los MX identifican intercambiadores de correo del dominio. En general se intenta primero la menor preferencia numérica: 10 antes que 20. No implica que ese servidor particular haya recibido todos los correos; se deben cotejar los encabezados y registros reales.

53 · Envelope vs cabecera From

Referencia: Ej. 5-6; teoría 06, envelope

En una transacción SMTP, MAIL FROM es bounce@proveedor.example, mientras el encabezado From dice direccion@empresa.example. ¿Tienen que coincidir? ¿Cuál participa directamente en el enrutamiento de rebotes?

Solución: No necesariamente coinciden: el remitente del envelope SMTP es independiente del From visible del mensaje. MAIL FROM indica la dirección usada para devoluciones de errores de entrega; el encabezado From es informativo. La discrepancia requiere investigación, pero no prueba por sí misma phishing.

54 · Leer saltos Received

Referencia: Ej. 5-6; teoría 06, Received

Identificá en la traza sintética qué IP entregó el correo a mx.destino.example y cuál es un salto interno. ¿Podés identificar de forma concluyente a la persona que lo creó?

```
Received: from mx.destino.example (10.0.0.9)
by buzones.destino.example
Received: from mx.origen.example (203.0.113.7)
by mx.destino.example
```

Solución: El salto mx.origen.example [203.0.113.7] → mx.destino.example es el servidor que se conectó al MX destino. El salto desde mx.destino.example [10.0.0.9] a buzones.destino.example es interno. Los Received añadidos por servidores confiables describen saltos; no atribuyen autoría humana, y las cabeceras más antiguas pueden falsificarse.

55 · IP privada en cabeceras

Referencia: Ej. 5-6; teoría 06, RFC1918

¿Cuáles son los tres rangos privados IPv4 de RFC 1918 y por qué no deben confundirse con la IP pública de origen de un incidente?

Solución: Son 10.0.0.0/8, 172.16.0.0/12 y 192.168.0.0/16. Pueden aparecer en saltos internos, pero no se enrutan de manera pública en Internet; para contactar a un tercero se busca la IP pública del servidor que estableció la conexión observada.

56 · Caso completo de correo

Referencia: Ej. 5-6; análisis de headers

A partir del extracto sintético determiná destinatario, MX receptor, IP pública del emisor inmediato y forma de encontrar el correo de denuncia.

```
To: ana@universidad.example
Received: from relay.remoto.example (198.51.100.44)
by mx.universidad.example with ESMTP
Subject: Aviso
```

Solución: Destinatario: ana@universidad.example; MX receptor: mx.universidad.example; IP del servidor que se conectó: 198.51.100.44; contacto: hacer RDAP/WHOIS sobre esa IP y obtener el contacto abuse del bloque. Los dominios y direcciones de documentación de este caso son ficticios.

57 · From y Reply-To

Referencia: Ej. 5-7; encabezados Reply-To

Un correo muestra From: soporte@empresa.example y Reply-To: pagos@otro.example. ¿Qué sucederá habitualmente si el destinatario pulsa «Responder» y qué sospecha amerita estudiar?

Solución: La respuesta suele dirigirse a Reply-To (pagos@otro.example), no al From visible. Puede ser legítimo en flujos de soporte, pero también servir para desviar respuestas a cuentas controladas por terceros. Se analizan contexto, rutas, dominio, autenticación y contenido.

58 · Spoofing sin acceso al servidor original

Referencia: Ej. 7; suplantación de remitentes

Aparecen mensajes con From de cuentas que no existen en el dominio, pero el administrador no observa envíos en su SMTP. ¿Qué hipótesis explica el caso sin asumir que robaron esas cuentas?

Solución: La suplantación de identidad del remitente (email spoofing): otro servidor puede transmitir un mensaje cuyo encabezado From declara el dominio ajeno. Hay que examinar la ruta Received y los resultados de validación del origen, y revisar la configuración de protección del dominio. La falta de logs locales no prueba sola una causa concreta, pero es compatible con esa hipótesis.

59 · Autenticación de correo

Referencia: Ej. 7; extensión aplicada

En el contexto de una investigación de spoofing, ¿qué función general cumplen SPF, DKIM y DMARC? ¿Por qué no alcanzan las capturas del From para atribuir un emisor?

Solución: SPF permite evaluar servidores autorizados para el dominio de envelope; DKIM usa firmas criptográficas vinculadas a un dominio; DMARC expresa políticas y alineación con el From visible. Son verificaciones complementarias para estudiar spoofing, no pruebas infalibles de autoría personal. Esta pregunta amplía operativamente el escenario del ej. 7.

60 · Detectar fuerza bruta SSH

Referencia: Ej. 8; teoría 07, incidente

Clasificá la actividad del extracto: ¿indica un ataque por intentos reiterados de contraseña? ¿Hubo un inicio de sesión exitoso desde 203.0.113.66?

```
22:01:01 Failed password for root from 203.0.113.66
22:01:03 Failed password for admin from 203.0.113.66
22:01:05 Failed password for invalid user prueba from 203.0.113.66
```

Solución: La secuencia de fallos para root, admin y usuario inválido desde la misma IP en segundos sugiere un ataque automatizado de prueba de credenciales o enumeración. No hay línea Accepted para esa IP: el extracto no evidencia un acceso exitoso, aunque el análisis completo requiere más logs.

61 · Accepted vs Failed

Referencia: Ej. 8; logs de autenticación

Un log SSH contiene «Accepted publickey for deploy» y otro «Failed password for root». ¿Qué hecho prueba cada una? ¿Por qué no conviene llamar «ataque exitoso» a cualquier uso de sudo?

Solución: Accepted publickey significa que el servidor aceptó autenticación mediante clave pública para ese usuario; Failed password señala un intento fallido. Que una sesión use sudo no demuestra malicia: pueden ser acciones administrativas válidas. Hay que correlacionar IP, autorización, comandos, horarios y actividad posterior.

62 · ¿Pertenece al ámbito del CSIRT?

Referencia: Ej. 8; teorías 03 y 07, pertinencia

El CSIRT universitario recibe quejas de que una IP de la Universidad está intentando acceder por fuerza bruta a servidores externos. Aunque la víctima sea ajena, ¿es pertinente?

Solución: Sí, porque la práctica y la teoría incluyen incidentes que afectan a la comunidad objetivo y también aquellos originados desde recursos bajo su administración. Deben verificar la IP, alcance temporal y actividad, priorizar y coordinar con su responsable.

63 · Correo de denuncia técnicamente útil

Referencia: Ej. 8; teoría 07, notificación

Enumerá qué evidencia incluirías al notificar intentos SSH maliciosos desde una IP pública asignada a otra organización.

Solución: Incluiría IP de origen, destino/servicio, tipo de actividad, timestamps exactos y zona horaria, fragmentos de logs suficientes, volumen o frecuencia, estado de éxito/fallo, punto de contacto abuse y forma segura de compartir evidencia. Evitaría acusar a una persona sin fundamento y protegería datos sensibles.

64 · Canal encubierto en ICMP

Referencia: Ej. 9; ICMP covert channel

En una captura, cuatro paquetes ICMP Echo Request contienen como primeros bytes de datos 49, 43, 7b y 7d (hex) en ese orden. ¿Qué mensaje producen si se interpretan como ASCII? ¿Por qué el uso de ping no garantiza benignidad?

```
ICMP payloads: 49 | 43 | 7b | 7d
```

Solución: Los bytes 0x49 0x43 0x7b 0x7d corresponden a IC{}. Los campos de datos ICMP pueden transportar bytes arbitrarios; un programa puede abusar de ellos como canal encubierto. Se debe verificar secuencia y contexto, ya que el mero hallazgo de datos legibles no prueba exfiltración.

65 · Canal encubierto en etiquetas DNS

Referencia: Ej. 10; covert channel por DNS

Se capturó una consulta al nombre 49437b646e737d.data.example. Tomá la primera etiqueta como bytes hexadecimales; ¿qué texto representa y qué indicios buscarías para evaluar exfiltración?

```
49437b646e737d.data.example
```

Solución: La primera etiqueta es 49 43 7b 64 6e 73 7d = IC{dns}. Buscaría consultas frecuentes a subdominios únicos, etiquetas largas con alta variabilidad, secuencias reconstruibles, tipos de consulta y respuestas. Se trata de un ejemplo sintético; DNS también puede transportar etiquetas largas legítimamente.

66 · Procedimiento con Wireshark/tshark

Referencia: Ej. 9-10; estrategia de PCAP

Tenés un PCAP con un supuesto canal encubierto, pero desconocés el protocolo. Describí una investigación que permita reproducir el hallazgo.

Solución: Primero inventariaría protocolos, conversaciones, frecuencias, tamaños y hosts. Luego filtraría flujos sospechosos (p. ej., ICMP o DNS), reconstruiría el orden cronológico y extraería campos de payload o etiquetas, evaluando hex/Base64/ASCII sin asumir un resultado. Guardaría filtro, comandos y evidencia para el writeup.

67 · Ataque desde dispositivo HID

Referencia: Ej. 11; USB Rubber Ducky

Un pendrive «Rubber Ducky» ejecuta instrucciones que se ven como pulsaciones de teclado. ¿Por qué podría actuar sin que el usuario abra un archivo ejecutable?

Solución: Estos dispositivos pueden presentarse como interfaz humana (HID), por ejemplo un teclado, e inyectar secuencias de teclas cuando el sistema los reconoce. Es distinto de un archivo de almacenamiento convencional. Deben inspeccionarse el script o payload disponible, las acciones observadas y las políticas de dispositivos USB.

68 · Interpretar un script inocuo

Referencia: Ej. 11; reconstrucción de acciones HID

Un archivo de ejemplo del dispositivo contiene DELAY 1000, GUI r, STRING notepad, ENTER. Sin ejecutarlo, explicá qué intenta realizar.

```
DELAY 1000
GUI r
STRING notepad
ENTER
```

Solución: Espera un segundo, abre la interfaz de ejecución (tecla Windows + R), escribe «notepad» y pulsa Enter. Sirve para demostrar que instrucciones de texto pueden traducirse a acciones de teclado. La sintaxis y su ejecución efectiva dependen del firmware/entorno concreto.

69 · Datos invisibles en texto

Referencia: Ej. 12; caracteres no visibles

Dos flags parecen idénticas en el editor, pero una contiene un carácter U+200B entre «se» y «creto». ¿Cómo detectarías el carácter invisible y por qué puede afectar la comparación?

```
Visible: IC{secreto}
Oculta: IC{se\u200bcreto}
```

Solución: Revisaría puntos de código Unicode, longitud de cadenas o una vista escapada como Python repr()/encode("unicode_escape"). U+200B es un espacio de ancho cero: no suele verse, pero sí forma parte de la secuencia de caracteres y puede cambiar validaciones exactas.

PRÁCTICA 2 · MALWARE · PARTE 3

70 · Primera triage de un ejecutable

Referencia: Ej. 13; teoría 08, análisis estático

Sin ejecutar estatico.exe, describí una secuencia inicial de análisis que identifique tipo de binario, imports, cadenas e IOC.

Solución: Calcular hash (p. ej. SHA-256), usar file o un inspector PE, revisar cabeceras/secciones, extraer strings ASCII y Unicode, observar imports/recursos y correlacionar artefactos plausibles (dominios, rutas, claves). Consultas a inteligencia pública se valoran con cuidado por posible exposición de muestras. Los indicios no son prueba concluyente de comportamiento.

71 · Magic bytes y formato

Referencia: Ej. 13; teoría 08, PE

El principio de un archivo contiene 4d 5a en hexadecimal. ¿Qué formato sugiere y por qué no alcanza para clasificarlo como malicioso?

```
00000000: 4d 5a ...
```

Solución: 4d 5a corresponde a MZ, firma inicial característica de ejecutables DOS/PE de Windows. Indica una posible estructura de ejecutable, no la intención del archivo. Hay que verificar el resto de cabeceras y estudiar imports, secciones, recursos y comportamiento.

72 · IOC frente a evidencia débil

Referencia: Ej. 13; teoría 08, IOC

Un binario contiene un dominio remoto, una ruta local, la cadena «password» y un SHA-256 conocido. ¿Cuáles podrían ser IOC útiles? ¿Qué aclaración corresponde hacer?

Solución: Hash, dominio e indicadores específicos del sistema de archivos pueden funcionar como IOC si se confirma su vínculo con el incidente; «password» es demasiado genérico. La presencia de una cadena aislada puede ser dato no usado o señuelo. Deben documentarse contexto, confianza y alcance del indicador.

73 · Inferencias a partir de imports

Referencia: Ej. 13; teoría 08, imports

Una muestra PE importa URLDownloadToFile y RegSetValueEx. ¿Qué comportamientos sospecharías y qué límite tiene esta inferencia?

Solución: URLDownloadToFile sugiere capacidad de descargar a disco; RegSetValueEx indica que puede escribir valores del registro. Combinadas, las funciones ameritan buscar descarga y posible persistencia. Las importaciones no prueban que se invoquen en todas las ejecuciones ni que sean necesariamente maliciosas.

74 · Indicios de empaquetamiento

Referencia: Ej. 13; teoría 08, packers

Un ejecutable tiene muy pocas cadenas, importa LoadLibrary y GetProcAddress, y presenta tamaños de secciones inusuales. ¿Qué hipótesis investigarías?

Solución: Podría estar empaquetado u ofuscado, ocultando imports/cadenas hasta el momento de ejecución. Revisaría entropía, secciones, empaquetadores conocidos y comportamiento en un entorno aislado. Estas señales también pueden aparecer en programas legítimos; no bastan por sí solas para declararlo malware.

75 · Clasificación por comportamiento

Referencia: Ej. 14; downloader

Un programa se inicia, descarga una segunda pieza desde una URL y la ejecuta. ¿Qué categoría funcional de malware describe mejor lo observado? ¿Qué IOC registrarías?

Solución: Es compatible con un downloader, porque su papel principal observado es obtener y poner en marcha otra carga. Registraría URL/dominio/IP según disponibilidad, ruta y nombre de archivo descargado, hashes, proceso hijo, mecanismo de ejecución y persistencia si existiera. Sin muestra no puede conocerse su URL real.

76 · Plan de ejecución aislada

Referencia: Ej. 14-16; teoría 08, dinámica

Antes de ejecutar una muestra sospechosa en Windows, ¿qué precauciones tomarías para estudiar su comportamiento sin exponer otros equipos?

Solución: Usaría una VM o laboratorio aislado con snapshot inicial; evitaría carpetas compartidas, portapapeles innecesario y conectividad directa a la red de la organización; configuraría una red controlada o servicios simulados, capturaría actividad y restauraría el snapshot después. Es importante conservar evidencia y no confiar en que una sola ejecución cubre todas las ramas.

77 · Interpretar un árbol de procesos

Referencia: Ej. 14-16; teoría 08, procesos

Un proceso muestra crea.exe → powershell.exe → segundo.exe durante el análisis dinámico. ¿Qué hipótesis podrías plantear y cómo la contrastarías?

Solución: La cadena es compatible con un programa que invoca un intérprete de comandos para lanzar otra carga. Hay que verificar línea de comandos, ruta del ejecutable hijo, hashes, actividad de red, archivos y eventos; sólo el árbol de procesos no permite confirmar la finalidad ni si el lanzamiento tuvo éxito.

78 · Persistencia por Run

Referencia: Ej. 14-16; teoría 08, Run keys

Una muestra crea HKCU\Software\Microsoft\Windows\CurrentVersion\Run\Updater con valor C:\Users\Ana\AppData\Roaming\updater.exe. ¿Cuándo intentaría ejecutarse y qué privilegios necesita para escribir esa rama?

```
HKCU\Software\Microsoft\Windows\CurrentVersion\Run\Updater
C:\Users\Ana\AppData\Roaming\updater.exe
```

Solución: La rama Run bajo HKCU permite lanzar el programa cuando ese usuario inicia sesión. El malware puede configurar esa entrada con los privilegios del usuario afectado, sin requerir necesariamente administrador. Debe confirmarse que el archivo exista y que la entrada esté habilitada y sea usada.

79 · Persistencia como servicio

Referencia: Ej. 14-16; teoría 08, servicios

Una muestra modifica HKLM\SYSTEM\CurrentControlSet\Services\ServicioX. ¿Qué mecanismo posible estudia la práctica y por qué difiere de HKCU Run?

Solución: La rama corresponde a configuraciones de servicios de Windows: puede instalar o alterar un servicio que arranca bajo condiciones definidas por el sistema. Es distinto de Run, que se ejecuta en inicio de sesión de usuario. Cambios de este tipo suelen requerir privilegios elevados; hay que inspeccionar ImagePath, Start y registros asociados.

80 · GUID como pista de persistencia

Referencia: Ej. 15; GUID y registro

El enunciado de una muestra pregunta por un GUID y un nombre específico de técnica de persistencia. ¿Qué evidencia haría falta para atribuir correctamente la técnica en vez de adivinarla?

Solución: Se necesita el GUID exacto observado, las claves/valores que lo contienen, procesos que los crean, artefactos relacionados y cuándo se ejecutan. Recién con esa evidencia se compara con mecanismos conocidos, por ejemplo los explicados en la charla «The Art of Persistence» que cita la teoría. Sin muestra ni registros no hay un GUID deducible.

81 · Conexión fallida y ruta alternativa

Referencia: Ej. 16; red y fallbacks

El binario intenta contactar 203.0.113.88:4444 sin éxito y luego abre https://control.example/ingest. ¿Qué indicadores anotarías por separado y qué no se puede inferir del primer intento fallido?

```
Fallo: 203.0.113.88:4444
Éxito: https://control.example/ingest
```

Solución: Registraría IP y puerto del primer intento, dominio y URL completa de la segunda conexión, timestamp, protocolo y resultado de ambas. La primera falla no prueba que el servidor de destino sea inexistente ni que el malware se detenga. En este ejemplo los identificadores son de documentación, no IOC de una muestra real.

82 · Listado de directorio y respuesta HTTP

Referencia: Ej. 16; exfiltración

Una captura muestra HTTP POST con un listado de nombres de archivos del directorio C:\Datos y respuesta HTTP 200. ¿Qué se puede afirmar, y qué NO, sobre la exfiltración?

```
POST /ingest HTTP/1.1
Body: C:\Datos\a.txt, C:\Datos\b.txt
HTTP/1.1 200 OK
```

Solución: Se observó el envío de una lista de nombres de archivos a un destino remoto y una respuesta HTTP 200 (la solicitud fue atendida según el protocolo). No implica por sí mismo que se hayan transferido los contenidos de esos archivos ni que el servidor haya conservado la información. Hay que corroborar el cuerpo enviado, la respuesta y el resto del tráfico.

83 · Ofuscación de VBScript

Referencia: Ej. 17; ofuscado.vbs

Un VBS construye texto usando concatenaciones y la función Chr, en vez de escribir las palabras directamente. ¿Qué técnica general está empleando y cómo lo analizarías sin ejecutarlo?

Solución: Es ofuscación de cadenas mediante reconstrucción dinámica, con concatenación y códigos numéricos de caracteres. Se pueden identificar las llamadas a Chr, reconstruir literales y rastrear qué funciones recibirían esas cadenas. La técnica concreta puede combinarse con otras (p. ej. inversión o Base64), que sólo la muestra permitiría confirmar.

84 · Resolver una cadena ofuscada

Referencia: Ej. 17; análisis de script

Sin ejecutar VBScript, resolvé Chr(73) & Chr(67) & Chr(123) & Chr(125), donde Chr interpreta códigos decimales. ¿Por qué este patrón podría usarse para ocultar IOC?

```
Chr(73) & Chr(67) & Chr(123) & Chr(125)
```

Solución: Los valores corresponden a I, C, { y }, así que se construye IC{}. El contenido no aparece como literal contiguo en una búsqueda simple de strings, lo que puede dificultar un análisis superficial. Un analista debe reconstruir expresiones antes de concluir que no hay cadenas relevantes.

85 · Macros en documento de Word

Referencia: Ej. 18; reto.docm

Un empleado abrió reto.docm recibido en un correo sospechoso. ¿Qué características investigarías y por qué el sufijo .docm es relevante?

Solución: docm es un documento habilitado para macros de Word. Analizaría metadatos, proyecto VBA, autoejecución (p. ej., AutoOpen/Document_Open), cadenas/URLs, llamadas a procesos y archivos creados, antes de considerar ejecución controlada. La extensión no prueba malicia y sin el archivo no se sabe su payload.

86 · Flujo seguro en documentos sospechosos

Referencia: Ej. 18-19; análisis sin ejecución

Compará un análisis inicial de un .docm con un .xls sospechoso: ¿qué elementos coinciden y cuáles pueden diferir?

Solución: En ambos: identificar tipo real, calcular hash, inspeccionar metadatos, contenido incrustado, vínculos externos, fórmulas/código y artefactos extraídos. En .docm se prioriza VBA de Word y eventos de apertura; en Excel también pueden existir macros, fórmulas, conexiones externas y otros mecanismos propios de hojas. No se deben abrir con ejecución activa en un equipo común.

87 · Promesa financiera como vector social

Referencia: Ej. 19; hoja de cálculo

Un archivo bitcoin_price_predictor.xls llega con promesa de ganancias extraordinarias. ¿Qué componente de ingeniería social detectás y qué evidencia técnica necesitarías antes de asegurar que es malware?

Solución: La promesa de rentabilidad y autoridad aparente incentiva que la víctima abra y habilite contenido. Para atribuir malicia se requieren indicadores observables: macros, conexiones, descargas, creación de procesos, persistencia, etc. El nombre del archivo y el reclamo comercial no prueban ejecución maliciosa.

88 · Herramientas por objetivo de observación

Referencia: Ej. 13-19; teoría 08, herramientas

Asociá Regshot, Autoruns, Procmon, Wireshark y Process Explorer con una pregunta de análisis de malware que cada una puede ayudar a responder.

Solución: Regshot: ¿qué entradas del registro cambiaron entre dos instantes? Autoruns: ¿qué mecanismos de autoarranque quedaron configurados? Procmon: ¿qué operaciones de registro/archivos/procesos realiza la muestra? Wireshark: ¿qué tráfico genera? Process Explorer: ¿qué procesos, hijos y módulos participan? Ninguna herramienta aislada prueba todos los comportamientos.

89 · Correlación de IOC

Referencia: Ej. 13-19; análisis estático/dinámico

Una URL aparece como string en un PE, pero el análisis dinámico no registra conexiones. ¿Cómo lo informarías sin sobreafirmar?

Solución: La URL es un indicador estático candidato, no una conexión confirmada. Puede haber una rama no ejecutada, requisitos del entorno, ofuscación adicional o simplemente un dato que no se usa. Documentaría búsqueda estática, observación dinámica, entorno y limitaciones antes de publicar IOC de red como validado.

90 · Informe de un incidente mixto

Referencia: Ej. 20; reto integrador

Una PC envía consultas DNS anómalas, tiene una entrada Run nueva y un documento macro recibido por email. Proponé una secuencia de investigación que conecte artefactos sin asumir causalidad.

Solución: Preservar evidencia y tiempos; analizar el email (Received, From, Reply-To y adjunto); identificar documento y macros; calcular hashes; observar la clave Run y archivo referenciado; correlacionar procesos y DNS/PCAP; contrastar IOC y determinar alcance en otras máquinas; notificar al CSIRT. Correlación temporal es una pista, no prueba por sí sola que el documento causó todo.

91 · Priorización y contención

Referencia: Ej. 14-20; teorías 03, 07 y 08, CSIRT

Si el malware sólo descargó un archivo en un laboratorio de test y, en otro caso, se exfiltran listados de directorios desde un servidor universitario crítico, ¿qué incidente priorizarías y por qué?

Solución: Priorizaría el servidor crítico con exfiltración observada por la exposición de información y el impacto potencial sobre servicios y terceros. De todos modos evaluaría criticidad real y evidencia en ambos casos. Acciones típicas incluyen aislar el activo afectado con coordinación, conservar registros, identificar IOC y revisar persistencia y alcance.

92 · Writeup verificable

Referencia: Ej. 14-20; teoría 07 y documento 02

Estructurá un writeup de una muestra sin acceso a Internet que incluya una hipótesis de persistencia, un IOC y una limitación. ¿Qué cuatro secciones recomienda la cátedra?

Solución: El material «02 Writeup example» propone Enunciado, Solución, Reflexión y Flag. En la solución se detallan hipótesis, comandos/herramientas, evidencia de la clave de persistencia y IOC, más límites del ensayo. En reflexión se consignan dificultades y hallazgos; no se inventa una flag ni un resultado que requiere artefactos no aportados.